

Auditoría de Seguridad Interna: Botium Toys

Autor: Mauro Alejandro Guadarrama Garcia

Programa: Google Cybersecurity

1. Introducción al Problema

Botium Toys es una empresa estadounidense en crecimiento que desarrolla y vende juguetes, operando desde una única ubicación física que sirve como oficina, tienda y almacén. Recientemente, su presencia en línea ha experimentado un gran auge, atrayendo a múltiples clientes tanto en EE. UU. como en el extranjero (incluyendo la Unión Europea). Este crecimiento repentino ha sometido al departamento de TI a una presión considerable para soportar las operaciones comerciales globales y cumplir con las normativas internacionales sin un plan estructurado o escalable. La problemática central radica en que la empresa se expandió sin auditar su infraestructura, lo que generó preocupaciones gerenciales sobre la posible exposición de datos de pagos (tarjetas de crédito), falta de cumplimiento normativo y vulnerabilidad ante amenazas cibernéticas que podrían interrumpir el negocio.

2. Metodología de Solución

Para abordar esta problemática, se ejecutó una auditoría de seguridad interna exhaustiva utilizando un enfoque basado en riesgos, estructurado en las siguientes fases metodológicas:

- **Marco de Ciberseguridad del NIST:** Se aplicó la función de "Identificar" (Identify) del NIST CSF para comprender a fondo y gestionar los riesgos de ciberseguridad relacionados con los sistemas, activos, datos y capacidades del negocio.
- **Evaluación de Riesgos Inicial:** Se analizaron los controles existentes y los activos en peligro, resultando en una puntuación de riesgo alarmante de 8 sobre 10, impulsada por la falta de encriptación y los amplios privilegios de acceso no regulados.
- **Ejecución de Listas de Comprobación:** Se categorizaron y validaron los controles actuales de la organización (Técnicos, Administrativos y Físicos) cruzándolos directamente contra los estándares internacionales de la industria (PCI DSS, GDPR y SOC).

3. Puntos Clave Considerados en la Auditoría

- **Alcance (Scope):** La evaluación abarcó el programa completo de seguridad de Botium Toys, lo que implicó evaluar todos los activos (físicos y lógicos) junto con los procesos y procedimientos internos del departamento de TI.
- **Objetivos (Goals):** Determinar con precisión qué controles y mejores prácticas normativas necesitan ser implementados urgentemente para mejorar la postura de seguridad y reducir el riesgo de multas institucionales.
- **Inventario de Activos Críticos:** Datos personales y financieros de clientes (PII/SPII y tarjetas de crédito), sistemas de comercio electrónico, bases de datos locales, red interna y equipos de punto de venta.

4. Lista de Comprobación de Evaluación de Controles

Control	¿Implementado?	Justificación Técnica / Observaciones
Least Privilege	No	No hay controles para limitar el acceso; todos los empleados acceden a datos internos y de clientes.
Disaster recovery plans	No	Ausencia total de planes de recuperación para garantizar la continuidad del negocio.
Password policies	No	La política existe pero es deficiente y no requiere la complejidad mínima de la industria.
Separation of duties	No	Cualquier usuario puede acceder, modificar o interactuar con PII/SPII sin segmentación de roles.
Firewall	Sí	Operativo, filtrando tráfico no deseado o malicioso según reglas de seguridad definidas.

Control	¿Implementado?	Justificación Técnica / Observaciones
Intrusion detection system (IDS)	No	Imposibilidad actual de detectar anomalías que hayan penetrado la red perimetral.
Backups	No	No existen copias de seguridad de datos críticos, elevando el riesgo de pérdida irreversible.
Antivirus software	Sí	Software AV instalado y supervisado periódicamente por TI para cuarentenas de amenazas.
Manual monitoring for legacy systems	No	Mantenimiento de sistemas heredados inconsistente; carece de programación regular de monitoreo.
Encryption	No	La información de tarjetas de crédito se procesa, transmite y almacena en texto claro.
Password management system	No	Ausencia de gestión centralizada que aplique y haga cumplir los requisitos de contraseña.
Locks (offices, storefront, warehouse)	Sí	Controles físicos funcionales y adecuados implementados en toda la sede física.
CCTV surveillance	Sí	Sistemas de circuito cerrado preventivos y detectivos operando de forma actualizada.
Fire detection/prevention	Sí	Alarmas y rociadores funcionales para proteger los activos de hardware y el inventario físico.

5. Lista de Comprobación de Cumplimiento

5.1. Payment Card Industry Data Security Standard (PCI DSS)

Mejor Práctica (Best Practice)	¿Implementado?
Solo los usuarios autorizados tienen acceso a la información de las tarjetas de crédito de los clientes.	No
La información de las tarjetas de crédito se almacena, acepta, procesa y transmite en un entorno seguro.	No
Se han implementado procedimientos de cifrado de datos para asegurar las transacciones.	No
Adopción de políticas de gestión de contraseñas seguras.	No

5.2. General Data Protection Regulation (GDPR)

Mejor Práctica (Best Practice)	¿Implementado?
Los datos de los clientes de la U.E. se mantienen privados/seguros.	No
Existe un plan para notificar a los clientes de la U.E. en 72h si ocurre una filtración (brecha).	Sí
Garantizar que los datos estén clasificados y debidamente inventariados.	No
Políticas y procesos de privacidad vigentes para documentar y mantener los datos.	Sí

5.3. System and Organizations Controls (SOC tipo 1, SOC tipo 2)

Mejor Práctica (Best Practice)	¿Implementado?
Se han establecido políticas de acceso de usuarios.	No
Los datos confidenciales (PII/SPII) son confidenciales/privados.	No
La integridad de los datos garantiza que estos son consistentes, completos y exactos.	Sí
Los datos están disponibles para el personal autorizado.	Sí

6. Resumen de Recomendaciones de Mitigación

- **Adopción del Principio de Privilegio Mínimo (IAM):** Configurar controles de acceso (Access Control Lists) y aplicar la separación de funciones. Revocar el acceso universal y restringir de inmediato la lectura de las bases de datos de PII y tarjetas de crédito únicamente al personal justificado.
- **Despliegue de Criptografía (Encryption):** Implementar controles técnicos para cifrar los datos financieros tanto en reposo (bases de datos internas) como en tránsito, para dar un cumplimiento primario a los requerimientos del PCI DSS.
- **Resiliencia y Continuidad (DRP y Backups):** Establecer y probar un plan estructurado de Recuperación ante Desastres. Configurar un protocolo de copias de seguridad de datos y aislar dichos backups en ubicaciones seguras.
- **Defensa en Profundidad Perimetral:** Dado que el firewall es insuficiente de forma aislada, instalar y configurar un Sistema de Detección/Prevención de Intrusos (IDS/IPS) para vigilar el comportamiento anómalo en la red interna.
- **Robustez de Autenticación:** Implementar un gestor de identidades o contraseñas centralizado para forzar requisitos mínimos de longitud (8 caracteres), complejidad y rotación, disminuyendo la superficie de ataque frente a técnicas de fuerza bruta.